

תכנות מערכות דפנסיבי – ממ"ן 15 – מסמך חולשות

שם : עידו קלמן, ת"ז : 331771535

1. תקיפת מניעת שירות – DDoS/DoS

הפרוטוקול לא מגדיר הגבלה על כמות החיבורים הקיימים לשרת ועל ניהול מהשאבים במצב של חיבורים רבים של משתמשים. כתוצאה מכך תוקף בעל משאבים מספיקים יכול להציף את השרת בכמות גדולה של חיבורים או בקשות TCP ולהביא אותו למצב של עומס במקרה הטוב, או במקרה הגרוע להקריס אותו ולמנוע את היכולת לספק שירות לכל שאר המשתמשים של התוכנה.

הצעת פתרון: יש המון דרכים להקשות על התקפות מסוג זה, למשל אפשר לנתר בצורה דינאמית את התקשורת שמתקבלת אצל השרת ולחסום כתובות IP כאשר מזוהה לקוח בעל התנהגות חשודה (הספמה, עומס גדול מאוד). אפשר גם לממש מנגנון של Rate Limiting (להקציב לכל לקוח כמות פעולות קבועה מקסימלית לביצוע בטווח זמן מסויים, כך שבסבירות גבוהה, השרת יוכל להתמודד עם כמות הפעולות שהוקצבו).

Threat	DDoS/DoS	
Affected Component	TCP Server	
Module Details	TCP Listener, server code that manages threads and connections	
Vulnerability Class	Resource Exhaustion	
Description	No limit on connections (see above)	
Result	Slow response, or complete system outage (see above)	
Prerequisites	Enough resources to crash	
Proposed remediation	See above	
Risk	Damage potential	9
	Reproducibility	8
	Exploitability	9
	Affected users	10
	Discoverability	8
	Overall	9

2. שימוש ב-IV מאופס בהצפנת AES

כמו שגם מפורט בחוברת המטלות, הפרוטוקול משתמש בהצפנת AES-CBC עם אורך מפתח של 128 סיביות, ככה שהערך IV – Initialized Vector **תמיד מאופס**. השימוש בערך IV שתמיד מאופס הוא לא בטוח ומסכן את ההצפנה מאחר ותוקף יכול לגלות מידע שאיננו אמור לדעת בעזרת ההודעות.

הצעת פתרון: יש להפיק וקטור אתחלתי אקראי בגודל 16 בתים לכל הצפנה ואף פעם לא להשתמש באותו וקטור התחלתי באופן קבוע בשימוש באלגוריתם כמו AES-CBC.

Threat	Cryptographic info leakage	
Affected Component	AES-CBC implementation	
Module Details	AESWrapper	
Vulnerability Class	Predictable IV	
Description	Usage of a constant IV field allows attacker to get some information about the communication	
Result	Information Leakage	
Prerequisites	Access to communication channel	
Proposed remediation	Create a random IV per encryption	
Risk	Damage potential	8
	Reproducibility	8
	Exploitability	8
	Affected users	9
	Discoverability	7
	Overall	8

3. מגבלת גודל הודעות / קבצים

הפרוטוקול מאפשר ללקוחות לשלוח הודעות לשרת ואחד לשני בלי הגבלה של גודל פרט לשדה: Payload size, שמוגבל בפרוטוקול ל-4 בתים. זה מאפשר לכל לקוח לשלוח לכל היותר 2^{32} בתים ללא הגבלה, שהם 4GB של מידע. במידה ולקוחות ישלחו באופן תדיר הודעות בגודל הזה בלי הגבלות, תוקף יכול להשביט את השרת (למשל, כי השרת שומר את ההודעות כ-BLOB במסד נתונים, ובשלב כלשהו המקום הפנוי בדיסק ייגמר), או לתפוס מקום גדול / להשביט את המערכת IO של לקוחות אחרים כשהם מושכים הודעות שמחכות להם בשרת.

הערה: הפרוטוקול בהגדרתו מאפשר לכל לקוח לתקשר עם כל לקוח אחר ולכן יש חשש שהודעות "ספאם" יפגעו בלקוחות אחרים, כי כל שנדרש לדעת הוא שם המשתמש של הנתקף (שאפשר גם ככה להשיג אותו דרך אופציה 120 בפרוטוקול).

הצעת פתרון: ניתן לממש כחלק מהפרוטוקול שליחה בצ'אנקים (Chunks) ובצורה הזאת להעביר הודעות גדולות מאוד בחלוקה למקטעים קטנים, אפשר גם להגביל בזמן את השהות של הודעות במסד הנתונים אם הן לא נקראות ובמיוחד להודעות גדולות שמגיעות מהלקוחות כדי שהן יימחקו במהירות מהדיסק, וגם לתשאל את הלקוח אם הוא מעוניין לרשום את התוכן לדיסק, לפני הכתיבה.

Threat	Resource Exhaustion	
Affected Component	IO system, DB storage	
Module Details	Server & client buffers and DB	
Vulnerability Class	Lack of size limits	
Description	See above	
Result	Full I/O, Server Slowness / Crash	
Prerequisites	Any connection to the server	
Proposed remediation	See above	
Risk	Damage potential	8
	Reproducibility	10
	Exploitability	8
	Affected users	9
	Discoverability	8
	Overall	8

Man In The Middle – MITM .4

הפרוטוקול ממומש על גבי תקשורת TCP בסיסית ולא מוצפנת ביחס לשרת, ואין אימות של השרת או של הלקוח אחד עם השני, ולכן תוקף בפוזיציה של MITM יכול ליירט הודעות, לשנות אותן, ולשלוח הודעות בהתחזות ללקוח לשרת.

הצעת פתרון: לממש את הפרוטוקול מעל שכבת הצפנה כמו TLS, להצפין את התקשורת מול השרת (יש חלקים מהשרת כמו המפתח הציבורי שעוברים בלי הצפנה לשרת מהלקוח בהגדרת הפרוטוקול).

Threat	MITM	
Affected Component	TCP layer, client-server communication	
Module Details	Poor implementation of TCP with no TLS	
Vulnerability Class	Lack of encryption	
Description	See above	
,Result	Data disclosed, phishing, key exchange	
Prerequisites	Being MITM (maybe as Proxy)	
Proposed remediation	See above	
Risk	Damage potential	10
	Reproducibility	8
	Exploitability	8
	Affected users	10
	Discoverability	7
	Overall	9

5. התחזות ללקוח וחשיפת הודעות

מזהה ה-UUID של כל לקוח הוא גלוי ולקוח לא נדרש להוכיח את הבעלות שלו על המפתח הציבורי, ולכן כל תוקף שגונב את המזהה של לקוח אחר (ששוב, גלוי עם בקשה 120), יכול למשל לקרוא בשבילו את ההודעות שלו ושל משתמשים אחרים על ידי הזרקה של הקובץ me.info. בנוסף זה גם מאפשר לתוקף לקבל פרימיטיב של "בדיקת קיום משתמש בהינתן UUID" – אפשר לנסות להשתמש בו ולראות אם השרת מחזיר תשובה לגיטימית, כי השרת יענה בשגיאה ל-UUID שהתקבל שלא מייצג לקוח במסד הנתונים.

הצעת פתרון: למשל, לממש בפרוטוקול מנגנון הצפנה בסיסי עם סיסמה שנדרשת על מנת להתחבר לחשבון בכל Session שנוצר בין השרת ללקוח.

Threat	Account impersonation	
Affected Component	Identity management	
Module Details	Server trusting UUID alone	
Vulnerability Class	Auth bypass	
Description	See above	
Result	Identity theft	
Prerequisites	Access to attacked UUID – which is public	
Proposed remediation	See above	
Risk	Damage potential	9
	Reproducibility	8
	Exploitability	10
	Affected users	9
	Discoverability	8
	Overall	9

הערה חשובה:

1. בתוך התיקייה src נמצאים התיקיות client ו-server שבתוכם קבצי הלקוח והשרת בהתאמה.
2. כדי להריץ את השרת, הרץ python app.py מתוך התיקייה server לאחר החילוץ.
3. קבצי הclient לא מכילים תיקיות על מנת שיהיה קל להוסיף אותם לפרויקט VS בלי בעיות include.
4. התיקייה tests מכילה המון בדיקות שביצעתי עם 2 לקוחות ומראה את הפונקציונליות של התוכנה

תודה!

סוף